

IDEA

Build a B2B mobile-first pharmacy ordering app where a retail pharmacist (the retailer) can browse medicines from multiple distributors, place orders, manage a cart, see active and closed orders, and view their store profile. After login, the retailer lands on a 4-tab dashboard: Home (offers carousel + medicine search + quick links to Distributors / Schemes / Generic Medicines / Scan Prescription / Outstanding Payments), Orders (Active / Closed sub-tabs), Cart (line items with distributor + price), Profile (name, license number, favourites, store location).

Decision: WROTE_FILES

TIMESTAMP	2026-05-02T19:01:27.933Z
TOTAL TIME	2 ms across 9 step(s)
VALIDATION	valid · 6 feature(s), 10 task(s)
SELECTED TASK	t-orders-2 (developer, 3h) -> f-orders-tab
QA	PASS
CYBERSECURITY	GO
FILES WRITTEN	1 file(s), 5,050 bytes

This report captures the full agent chain (CEO -> CTO -> Engineering Manager -> Developer -> QA -> Cybersecurity). Each agent's complete output is included in the per-agent sections.

Steps

#	Step	Status	Duration	Notes
1	ceo	ok	0 ms	
2	cto	ok	0 ms	
3	engineering-manager	ok	0 ms	
4	validation	ok	1 ms	6 features, 10 tasks
5	task-selection	ok	0 ms	picked t-orders-2 (developer, 3h) under f-orders-tab
6	developer	ok	0 ms	
7	qa	ok	0 ms	decision=PASS
8	cybersecurity	ok	0 ms	decision=GO
9	file-writer	ok	1 ms	1 file(s), 5050 bytes

Validation

Valid — 6 feature(s), 10 task(s).

Selected task

Task: t-orders-2 — Build the Orders tab page at app/dashboard/orders/page.tsx with Active and Closed sub-tabs (segmented control). Each sub-tab calls GET /api/orders with the matching status group and renders order cards (distributor name, status pill with status-color, item count, total, placed-at relative time, expected-delivery when present). Empty-state copy for both tabs.

Assignee: developer

Estimate: 3 h

Feature: f-orders-tab — Orders tab + place-order API

Files written

1 file(s), 5,050 bytes total.

Path	Bytes
app/dashboard/orders/page.tsx	5,050

CEO

Mission: Let an independent retail pharmacist place orders to every medicine distributor they buy from in one mobile-first app, replacing the WhatsApp + phone-call ordering loop they live in today.

OKRS

- Ship a retailer-only build with login and a 4-tab dashboard (Home, Orders, Cart, Profile) that supports the full search -> add-to-cart -> place-order -> see-in-active-orders loop within 14 days
- Convert 50% of the 6 pilot retailers from their current channel to at least one in-app order in the first 30 days post-launch
- Surface an outstanding-payments tile on the Home tab so retailers can see distributor-wise balance without calling, reducing reconciliation calls per retailer by 70% in the same window

PRIORITIES

- Stand up the authenticated 4-tab dashboard shell (mock retailer login + tab navigation) so every later task has a place to land in the UI
- Build the Home tab: search bar at the top, offers carousel, and the 5 quick-link tiles (Distributors, Schemes, Generic Medicines, Scan Prescription, Outstanding Payments)
- Build the Cart and Orders tabs end-to-end: cart line items with distributor + total, place-order action, and Active/Closed sub-tabs in Orders
- Build the Profile tab as a read-only retailer card (name, license number, favourites count, store location) plus the outstanding-payments stub it links to from Home

DELEGATION

CTO: Build a mobile-first Next.js 14 (App Router) + Tailwind webapp. Backend is Next.js Route Handlers in the same project; demo data lives in in-memory Maps seeded at boot (one pilot retailer, four distributors, ~20 medicines, three offers). Authentication is a mock cookie-based session: POST /api/auth/login takes a license number and sets a pharmacy-session cookie, middleware guards /dashboard/*. No real distributor integration, no real payments, no Postgres this cycle. Ship by end of day 8 with a runnable end-to-end loop: login -> search a medicine -> add to cart -> place order -> see it under Orders/Active -> view Profile.

CMO: Skip this cycle. Pilot is direct sign-up with the 6 retailers we already have a relationship with; no paid acquisition until cycle 2.

CFO: Back-of-envelope only: distributor commission percent x average order value x monthly orders per retailer. Re-validate before cycle 2; no spend this cycle other than the existing engineering team.

CPO: Own the product copy: empty states (no orders, empty cart, no offers), the 'outstanding payments' tile heading and per-distributor row, the 5 quick-link tile labels and supporting microcopy, and the order-status vocabulary (Placed / Acknowledged / Out for delivery / Delivered / Cancelled). Hand the copy sheet to CTO by end of day 2.

FULL CEO OUTPUT (JSON)

```
{
  "mission": "Let an independent retail pharmacist place orders to every medicine distributor they buy from in one mobile-first app, replacing the WhatsApp + phone-call ordering loop they live in today.",
  "okrs": [
    "Ship a retailer-only build with login and a 4-tab dashboard (Home, Orders, Cart, Profile) that supports the full search -> add-to-cart -> place-order -> see-in-active-orders loop within 14 days",
    "Convert 50% of the 6 pilot retailers from their current channel to at least one in-app order in the first 30 days post-launch",
  ]
}
```


ARCHITECTURE

Frontend:	Next.js 14 (App Router) + Tailwind CSS, mobile-first responsive layout. Authenticated /dashboard route renders a fixed bottom tab bar (Home / Orders / Cart / Profile) on small screens that promotes to a side rail at md+. Client components only where state is needed (search input, cart updates, tab toggles); everything else is a server component reading from the in-process data layer.
Backend:	Next.js Route Handlers under app/api/* in the same Next project (no separate Node service). Auth uses a signed cookie set via Next's cookies() API; middleware at the project root guards /dashboard/* and every /api/* route except /api/auth/login. All handlers are typed end-to-end via shared zod schemas in lib/api/contracts.ts.
Database:	In-memory storage via lib/db/store.ts (Map<string, Record>), seeded at module load with 1 pilot retailer, 4 distributors, ~20 medicines, 3 offers, and 2 outstanding-payment rows. The schema is shaped to match a future Postgres + Drizzle migration so the same TypeScript types survive the swap; no migration this cycle.
Infrastructure:	Single Vercel deploy (frontend + Route Handlers behind one origin). Static assets via Vercel CDN. No external services this cycle. Future cycles: Neon Postgres for persistence, per-distributor HTTP integration via a simple fanout, and S3-compatible storage for prescription scans.

API CONTRACTS (11)

- POST /api/auth/login — Pilot login: takes a retailer license number, looks it up in the in-memory store, sets the pharmacy-session cookie (HttpOnly, SameSite=Lax) and returns the retailer summary. No password this cycle (single pilot retailer per device).
 - POST /api/auth/logout — Clears the pharmacy-session cookie.
 - GET /api/medicines/search — Case-insensitive substring search over medicine name, brand, and generic name. Empty q returns the full catalogue (used by the search results page when a retailer lands without a query). Each result carries the distributor it ships from so the UI can render the price + supplier chip.
 - GET /api/distributors — List all distributors the retailer can buy from. Used by the Home tab quick-link and the cart line items.
 - GET /api/offers — List of currently-active offers shown in the Home tab carousel. Returned in sortOrder. Each entry references the distributor running the offer.
 - GET /api/cart — Returns the current retailer's cart, grouped by distributor with a per-distributor subtotal and a grand total. Drives the Cart tab.
 - POST /api/cart/items — Add a medicine to the current retailer's cart, or increment the qty if it is already there. Validates that the medicineId exists. Returns the updated cart payload (same shape as GET /api/cart) so the Cart tab can render without a second round-trip.
 - DELETE /api/cart/items/{medicineId} — Remove a medicine from the current retailer's cart. Returns the updated cart payload.
 - POST /api/orders — Place orders from the current retailer's cart. The cart is fanned out into one order per distributor (so the retailer's UI can show each supplier's order separately under Orders > Active). Cart is cleared on success.
 - GET /api/orders — List the retailer's orders, filtered by status group. status=active returns placed | acknowledged | out_for_delivery; status=closed returns delivered | cancelled. Sorted newest-first.
 - GET /api/profile — Returns the current retailer's profile card plus the outstanding-payments breakdown shown on the Home tab tile.
-

DATABASE SCHEMA (8)

- **retailers**
 - id: string primary key (uuid in production)
 - name: string not null (display name shown on Profile)
 - owner_name: string not null
 - license_number: string not null unique (used as login id this cycle)
 - store_name: string not null
 - store_address: string not null
 - phone: string not null
 - email: string not null
 - gstin: string not null
 - favourites_medicine_ids: string[] not null default []
 - created_at: timestamp not null
 - **distributors**
 - id: string primary key
 - name: string not null
 - region: string not null
 - supplier_code: string not null unique
 - contact_phone: string not null
 - contact_email: string not null
 - rating: number not null (0-5, decimal)
 - created_at: timestamp not null
 - **medicines**
 - id: string primary key
 - name: string not null
 - brand: string not null
 - manufacturer: string not null
 - generic_name: string not null
 - distributor_id: string not null references distributors(id)
 - mrp_paise: integer not null (≥ 0)
 - selling_price_paise: integer not null (≥ 0)
 - scheme: string nullable (e.g. '10+1 free' or null)
 - pack_size: string not null (e.g. '10 tablets', '100 ml syrup')
 - hsn_code: string not null
 - created_at: timestamp not null
 - **offers**
 - id: string primary key
 - title: string not null
 - description: string not null
 - distributor_id: string not null references distributors(id)
 - banner_label: string not null (short text shown on the gradient banner)
 - valid_until: timestamp not null
 - sort_order: integer not null (lower = earlier in the carousel)
 - created_at: timestamp not null
 - **cart_items**
 - id: string primary key
 - retailer_id: string not null references retailers(id)
 - medicine_id: string not null references medicines(id)
 - distributor_id: string not null references distributors(id) (denormalised from medicines for easy grouping)
 - qty: integer not null (≥ 1)
 - unit_price_paise: integer not null (frozen at add-to-cart time)
 - added_at: timestamp not null
-

- unique(retailer_id, medicine_id)
- **orders**
 - id: string primary key
 - retailer_id: string not null references retailers(id)
 - distributor_id: string not null references distributors(id)
 - status: string not null (one of: placed | acknowledged | out_for_delivery | delivered | cancelled)
 - placed_at: timestamp not null
 - expected_delivery: timestamp nullable
 - total_paise: integer not null (≥ 0)
 - item_count: integer not null (≥ 1)
- **order_items**
 - id: string primary key
 - order_id: string not null references orders(id)
 - medicine_id: string not null references medicines(id)
 - qty: integer not null (≥ 1)
 - unit_price_paise: integer not null
 - line_total_paise: integer not null
- **outstanding_payments**
 - id: string primary key
 - retailer_id: string not null references retailers(id)
 - distributor_id: string not null references distributors(id)
 - amount_due_paise: integer not null (≥ 0)
 - last_updated_at: timestamp not null
 - unique(retailer_id, distributor_id)

RISKS (6)

- security: mock cookie auth (single shared session secret, no password, no multi-device invalidation) is intentional for the pilot but unsafe for production; flag for a real auth task in cycle 2
- compliance: pharmacy ordering is regulated (drug schedules, Schedule H1/X tracking, narcotics audit trail). This cycle ignores schedule classification and prescription validation; both are mandatory before any non-pilot rollout
- data loss: in-memory Maps reset on every process restart. Acceptable for a demo, blocking for a customer pilot
- scaling: medicine search is a linear scan over the in-memory store. Fine for ~20 medicines; needs Postgres trigram index or Meilisearch beyond ~1000 SKUs
- mobile UX: 'Scan Prescription' is a placeholder tile this cycle; barcode + OCR scan needs a native shell or WebRTC + a vision model and is out of scope
- outstanding-payments accuracy: the per-distributor balance is currently a static seed; integration with each distributor's ledger is a downstream task and the tile must be labelled as 'last reconciled at <ts>' to avoid retailer confusion

FULL CTO OUTPUT (JSON)

```
{
  "architecture": {
    "frontend": "Next.js 14 (App Router) + Tailwind CSS, mobile-first responsive layout.
Authenticated /dashboard route renders a fixed bottom tab bar (Home / Orders / Cart / Profile) on
small screens that promotes to a side rail at md+. Client components only where state is needed
(search input, cart updates, tab toggles); everything else is a server component reading from the
in-process data layer.",
    "backend": "Next.js Route Handlers under app/api/* in the same Next project (no separate Node
service). Auth uses a signed cookie set via Next's cookies() API; middleware at the project root
guards /dashboard/* and every /api/* route except /api/auth/login. All handlers are typed end-to-
end via shared zod schemas in lib/api/contracts.ts.",
    "database": "In-memory storage via lib/db/store.ts (Map<string, Record>), seeded at module
load with 1 pilot retailer, 4 distributors, ~20 medicines, 3 offers, and 2 outstanding-payment
rows. The schema is shaped to match a future Postgres + Drizzle migration so the same TypeScript
types survive the swap; no migration this cycle.",
    "infrastructure": "Single Vercel deploy (frontend + Route Handlers behind one origin). Static
assets via Vercel CDN. No external services this cycle. Future cycles: Neon Postgres for
```


Engineering Manager

FEATURES (6)

- f-shell-auth (high) — App shell + mock retailer auth
- f-data-spine (high) — In-memory data spine + shared types
- f-home-tab (high) — Home tab
- f-orders-tab (high) — Orders tab + place-order API
- f-cart-tab (high) — Cart tab + cart APIs
- f-profile-tab (medium) — Profile tab

TASKS (10)

- t-orders-2 -> f-orders-tab · developer · 3h - Build the Orders tab page at `app/dashboard/orders/page.tsx` with Active and Closed sub-tabs (segmented control). Each sub-tab calls `GET /api/orders` with the matching status group and renders order cards (distributor name, status pill with status-color, item count, total, placed-at relative time, expected-delivery when present). Empty-state copy for both tabs.
- t-shell-1 -> f-shell-auth · developer · 4h - Set up the Next.js 14 + Tailwind project skeleton: `package.json` (next 14.2, react 18, tailwind 3, typescript 5, vitest), `tsconfig.json` with the `@/*` alias, `next.config.mjs`, `postcss.config.mjs`, `tailwind.config.ts` (mobile-first content globs), `app/globals.css` with the Tailwind directives + base background, `app/layout.tsx` with the `html/body` shell, and the public login page at `app/page.tsx` that posts to `/api/auth/login`. No auth handler yet (lands in `t-shell-2`); the page just calls `fetch` and redirects on success.
- t-shell-2 -> f-shell-auth · developer · 4h - Implement the mock auth: `POST /api/auth/login` (look up the retailer by license number against the in-memory store, set the pharmacy-session cookie `HttpOnly+SameSite=Lax` with a 30-day max-age), `POST /api/auth/logout` (clear the cookie), `middleware.ts` that gates `/dashboard/*` and every `/api/*` route except `/api/auth/login` (returns 401 JSON if missing cookie), a small `lib/auth/session.ts` helper that reads the current `retailerId` from the request cookies, and the authenticated `app/dashboard/layout.tsx` that renders the 4-tab bottom navigation (Home / Orders / Cart / Profile) and a stub `app/dashboard/page.tsx` that redirects to `/dashboard/home`.
- t-data-1 -> f-data-spine · developer · 4h - Implement the in-memory data spine: `lib/types.ts` (TypeScript types for Retailer, Distributor, Medicine, Offer, CartItem, Order, OrderItem, OutstandingPayment, OrderStatus, derived Money helpers) and `lib/db/store.ts` (Map-backed stores seeded at module import with 1 pilot retailer, 4 distributors, 20 medicines spanning the four distributors, 3 active offers, 2 outstanding-payment rows; CRUD helpers - `getRetailer`, `listDistributors`, `listOffers`, `searchMedicines(q)`, `getMedicine(id)`, `getCart(retailerId)`, `addCartItem`, `removeCartItem`, `clearCart`, `listOrders(retailerId, statusGroup)`, `createOrdersFromCart(retailerId)`, `getOutstandingForRetailer(retailerId)`).
- t-home-1 -> f-home-tab · developer · 3h - Implement the read APIs that drive the Home tab: `GET /api/medicines/search` (case-insensitive substring over name + brand + generic, returns each result with its distributor), `GET /api/distributors` (`id/name/region/rating` list), `GET /api/offers` (active offers in `sortOrder`, each with its distributor). All three use the auth-guarded session helper to identify the retailer (search results may carry per-retailer favourites later) and return 401 if the cookie is missing.
- t-home-2 -> f-home-tab · developer · 4h - Build the Home tab page at `app/dashboard/home/page.tsx`: greeting line with the retailer name, a search bar at the top that links to `/dashboard/search?q=...`, a horizontally scrollable offers carousel reading from `GET /api/offers`, the 5 quick-link tiles (Distributors, Schemes, Generic Medicines, Scan Prescription, Outstanding Payments), and an outstanding-payments summary tile that calls `GET /api/profile` and shows the total + per-distributor breakdown. Mobile-first Tailwind layout, snap-scroll on the carousel.
- t-cart-1 -> f-cart-tab · developer · 3h - Implement the cart APIs: `GET /api/cart` (returns the cart grouped by distributor with subtotals + grand total + `itemCount`, derived from the in-memory store), `POST /api/cart/items` (validates `medicineId` exists, increments `qty` if already present, returns the

same grouped payload), DELETE /api/cart/items/[medicineId] (removes the line, returns the same grouped payload). All three resolve the retailer via the session helper and 401 without it.

- t-cart-2 -> f-cart-tab · developer · 3h - Build the Cart tab page at app/dashboard/cart/page.tsx: groups the cart by distributor (heading per supplier with subtotal), each line shows name + brand + qty stepper + remove button + line total, sticky footer with the grand total and a Place Order button that POSTs to /api/orders and on success routes to /dashboard/orders?status=active. Empty-state copy when the cart is empty.
- t-orders-1 -> f-orders-tab · developer · 3h - Implement the orders APIs: GET /api/orders?status=active|closed (active = placed | acknowledged | out_for_delivery, closed = delivered | cancelled, sorted newest-first), POST /api/orders (reads the current retailer's cart, fans out into one order per distinct distributorId, copies cart_items into order_items, clears the cart, returns the new orderIds + count). 401 without the session cookie.
- t-profile-1 -> f-profile-tab · developer · 3h - Implement GET /api/profile (returns the current retailer plus the outstanding-payments breakdown grouped by distributor) and build the Profile tab page at app/dashboard/profile/page.tsx that renders the retailer card (avatar initials, name, store name, license number, owner name, GSTIN, store address, phone, email, favourites count) and an outstanding-payments section listing each distributor's amount-due with the grand total. A logout button at the bottom POSTs /api/auth/logout and routes to /.

FULL ENGINEERING MANAGER OUTPUT (JSON)

```
{
  "features": [
    {
      "id": "f-shell-auth",
      "name": "App shell + mock retailer auth",
      "description": "Next.js 14 + Tailwind project skeleton, the login page, and the authenticated /dashboard layout with the bottom tab bar that every other feature lives inside.",
      "priority": "high",
      "status": "pending"
    },
    {
      "id": "f-data-spine",
      "name": "In-memory data spine + shared types",
      "description": "Single source of truth for retailers, distributors, medicines, offers, cart items, orders, order items, and outstanding payments. In-memory Maps with seed data, plus the shared TypeScript types every Route Handler and page imports.",
      "priority": "high",
      "status": "pending"
    },
    {
      "id": "f-home-tab",
      "name": "Home tab",
      "description": "Search bar at the top, offers carousel, the 5 quick-link tiles (Distributors, Schemes, Generic Medicines, Scan Prescription, Outstanding Payments), and the supporting catalogue / offers / distributors APIs.",
      "priority": "high",
      "status": "pending"
    },
    {
      "id": "f-orders-tab",
      "name": "Orders tab + place-order API",
      "description": "Orders list page with Active and Closed sub-tabs, plus the POST /api/orders fanout (cart -> one order per distributor) and GET /api/orders status-grouped reader.",
      "priority": "high",
      "status": "pending"
    },
    {
      "id": "f-cart-tab",
      "name": "Cart tab + cart APIs",
      "description": "Cart page grouped by distributor with per-distributor subtotal and a grand total, plus the GET / POST / DELETE cart endpoints that drive it.",
      "priority": "high",
      "status": "pending"
    },
    {
      "id": "f-profile-tab",
      "name": "Profile tab",

```


Developer

Task: t-orders-2

IMPLEMENTATION PLAN

Build the Orders tab as a single server component (no client component needed - the Active/Closed sub-tabs are URL-based via `?status=active|closed` which Next 14 SSRs natively). `app/dashboard/orders/page.tsx` resolves the retailer via `getSession`, redirects to `/` when missing, derives the `OrderStatusGroup` from `searchParams.status` (defaults to 'active'), and reads `listOrders(retailerId, group)` directly from the in-memory store. Renders a header, a 2-column segmented-control nav (role='tablist', each tab is a Next Link with `aria-selected`), and a list of order cards. Each card shows the distributor name, a short order id, a status pill (colour-mapped per `OrderStatus`), and a 3-column dl with Items / Total / Placed (relative time). Expected-delivery line appears only when set. Empty-states are split per tab so the copy is meaningful (Active: 'Place one from the Cart tab', Closed: 'Delivered and cancelled orders will show up here').

FILES PRODUCED (1)

- `app/dashboard/orders/page.tsx` (5,050 bytes)

TESTS (2)

- Status pill colours map every `OrderStatus` to a non-empty Tailwind utility set.
- Orders page renders the segmented Active/Closed tabs and the right empty-state copy when there are no orders.

NOTES (3)

- URL-based tabs (Next Link to `?status=...`) instead of a client component with local state: Next 14 re-renders the server component on querystring change at zero cost, and links are crawlable + screen-reader-friendly without any extra ARIA work beyond `aria-selected`.
- Status pill colours follow a consistent semantic palette: placed = blue (info), acknowledged = indigo (next stage), out_for_delivery = amber (action in progress), delivered = emerald (success), cancelled = slate (neutral/closed). All colours pass WCAG AA on the white card background.
- Relative time is computed server-side. This means the 'placed Xm ago' label is fixed at render time; on a long-lived page the value goes stale. Acceptable for the pilot because every navigation re-renders. Cycle 2 can swap in a small client-side `<RelativeTime />` if real-time accuracy matters.

FULL DEVELOPER OUTPUT (JSON)

```
{
  "taskId": "t-orders-2",
  "implementationPlan": "Build the Orders tab as a single server component (no client component needed - the Active/Closed sub-tabs are URL-based via ?status=active|closed which Next 14 SSRs natively). app/dashboard/orders/page.tsx resolves the retailer via getSession, redirects to / when missing, derives the OrderStatusGroup from searchParams.status (defaults to 'active'), and reads listOrders(retailerId, group) directly from the in-memory store. Renders a header, a 2-column segmented-control nav (role='tablist', each tab is a Next Link with aria-selected), and a list of order cards. Each card shows the distributor name, a short order id, a status pill (colour-mapped per OrderStatus), and a 3-column dl with Items / Total / Placed (relative time). Expected-delivery line appears only when set. Empty-states are split per tab so the copy is meaningful (Active: 'Place one from the Cart tab', Closed: 'Delivered and cancelled orders will show up here').",
  "files": [
    {
      "path": "app/dashboard/orders/page.tsx",
      "content": "import Link from \"next/link\";\nimport { redirect } from \"next/navigation\";\n\nimport { getSession } from \"@/lib/auth/session\";\nimport { getDistributor, listOrders } from \"@/lib/db/store\";\nimport {\n  type Order,\n  type OrderStatus,\n  type OrderStatusGroup,\n  STATUS_LABELS,\n  paiseToRupees,\n} from \"@/lib/types\";\n\nexport const dynamic = \"force-dynamic\";\n\ninterface OrdersPageProps {\n  searchParams: { status?: string };\n}\n\nexport default function OrdersPage({ searchParams }: OrdersPageProps) {\n  const session = getSession();\n  if (!session) redirect(\"/\");\n  const group: OrderStatusGroup = searchParams.status === \"closed\" ? \"closed\" : \"active\";\n  const orders = listOrders(session.retailerId, group);\n\n  return (\n    <div className=\"space-y-4 px-4 pb-6 pt-6\">\n      <header>\n        <h1
```


QA

Decision: **PASS**
Test plan: 10 item(s)
Results: 10 pass, 0 fail
Bugs: 0

BUGS (0)

(none)

FULL QA OUTPUT (JSON)

```
{
  "taskId": "t-orders-2",
  "testPlan": [
    "Verify the file set lands the Orders tab as a single page file: app/dashboard/orders/
page.tsx.",
    "Verify the page is a server component that resolves the retailer via getSession + redirects
to / on miss.",
    "Verify searchParams.status defaults to 'active' when missing, and is coerced to 'closed'
only when literally 'closed' (any other string falls back to 'active').",
    "Verify the page reads listOrders(retailerId, group) directly from the in-memory store.",
    "Verify the segmented tablist renders 2 anchor links (Active, Closed) with role='tab' and
aria-selected reflecting the current group.",
    "Verify each order card shows distributor name, short order id, status pill, items / total /
placed-relative dl, and the expected-delivery line only when set.",
    "Verify status pill colours map every OrderStatus to a non-empty Tailwind class (placed/
acknowledged/out_for_delivery/delivered/cancelled).",
    "Verify the Active and Closed empty-states render distinct copy.",
    "Verify dynamic = 'force-dynamic' is exported.",
    "Search files[].content for forbidden placeholder strings."
  ],
  "results": [
    {
      "test": "Single page file lands the Orders tab.",
      "status": "pass",
      "details": "1 file: app/dashboard/orders/page.tsx (~5 KB). Tab content + helpers + status
colour map all in one module - small enough to navigate."
    },
    {
      "test": "Server component with session guard.",
      "status": "pass",
      "details": "No 'use client'. getSession() -> redirect('/') on null. Defence in depth on top
of the dashboard layout's own guard."
    },
    {
      "test": "?status defaulting and validation.",
      "status": "pass",
      "details": "group: OrderStatusGroup = searchParams.status === 'closed' ? 'closed' :
'active'. Strict equality means ?status=Closed (capital C), ?status=foo, ?status= all fall back
to 'active'. Belt-and-braces with the 400 validation on the API endpoint."
    },
    {
      "test": "Direct store read.",
      "status": "pass",
      "details": "listOrders(session.retailerId, group). Same in-process pattern as the home
page; no internal HTTP hop."
    },
    {
      "test": "Segmented tablist accessibility.",
      "status": "pass",
      "details": "<nav role='tablist'>. <TabLink> renders <Link role='tab' aria-selected={active}>. Active class set: bg-white text-brand-700 shadow. Inactive: text-slate-600. URL-based - the
back button works as expected."
    },
    {
      "test": "Order card layout.",
      "status": "pass",
      "details": "Header: distributor name (truncated for long names) + 'Order #<short
id>' (first 8 chars). Status pill on the right. dl with 3 columns (Items, Total, Placed).
Expected delivery line only renders if order.expectedDelivery is truthy."
    }
  ]
}
```


Cybersecurity

Decision:

GO

Summary:

Audited the Orders tab page. The change is a single server component that reads the session, validates the ?status query parameter against a closed enum, reads typed orders from the in-memory store, and renders escaped React text. No client-side state, no fetch calls, no LLM-mediated I/O. No critical, high, or medium-severity vulnerabilities were found. One low-severity item (no length cap on rendered distributor names) is recorded as a defence-in-depth note.

Prompt-injection risk:

None. The page issues no LLM call, performs no LLM-mediated I/O, renders no untrusted text as raw HTML (React escapes all text-content interpolation), and executes no shell or filesystem operation. The ?status query parameter is filtered to two literal values before reaching any logic.

VULNERABILITIES (1)

LOW

The order card renders distributor.name and the short order id directly into the JSX. Both fields originate from the in-memory store (server-controlled today), but if a future migration ever sources distributor names from a third-party catalogue, an attacker-controlled distributor name could land in the page. React would still escape the text content, so this is non-exploitable, but a 200-character distributor name would visually break the truncate utility.

- Recommendation: Cycle 2: at the data layer (lib/db/store.ts validators when Postgres lands), enforce distributor.name.length <= 80 and order.id format /^[a-z0-9-]+\$/. Defensive, non-blocking.

REQUIRED FIXES (0)

(none)

FULL CYBERSECURITY OUTPUT (JSON)

```
{
  "taskId": "t-orders-2",
  "summary": "Audited the Orders tab page. The change is a single server component that reads the session, validates the ?status query parameter against a closed enum, reads typed orders from the in-memory store, and renders escaped React text. No client-side state, no fetch calls, no LLM-mediated I/O. No critical, high, or medium-severity vulnerabilities were found. One low-severity item (no length cap on rendered distributor names) is recorded as a defence-in-depth note.",
  "vulnerabilities": [
    {
      "severity": "low",
      "description": "The order card renders distributor.name and the short order id directly into the JSX. Both fields originate from the in-memory store (server-controlled today), but if a future migration ever sources distributor names from a third-party catalogue, an attacker-controlled distributor name could land in the page. React would still escape the text content, so this is non-exploitable, but a 200-character distributor name would visually break the truncate utility.",
      "recommendation": "Cycle 2: at the data layer (lib/db/store.ts validators when Postgres lands), enforce distributor.name.length <= 80 and order.id format /^[a-z0-9-]+$/. Defensive, non-blocking."
    }
  ],
  "promptInjectionRisk": "None. The page issues no LLM call, performs no LLM-mediated I/O, renders no untrusted text as raw HTML (React escapes all text-content interpolation), and executes no shell or filesystem operation. The ?status query parameter is filtered to two literal values before reaching any logic.",
  "decision": "GO",
  "requiredFixes": []
}
```


